

ICS Threat Analysis (IEC 62443-based)

1 Introduction

This analysis follows principles from IEC 62443, which defines a structured approach to identifying threats in Industrial Control Systems (ICS) based on zones, conduits, and system integrity requirements.

The assessment uses a simplified STRIDE model adapted for ICS environments and considers three attacker profiles: external attackers, insiders, and opportunistic student-level actors within a lab or training environment.

Industrial systems are particularly sensitive because compromise is not limited to data loss; manipulation can directly affect physical processes, safety constraints, and production continuity.

2 Attacker Profiles

External attacker

Typically motivated by financial gain (ransomware), disruption, or opportunistic exploitation of exposed services. Often relies on phishing, misconfigured remote access, or known vulnerabilities.

Insider

A user with legitimate access (operator, engineer, contractor). Capable of bypassing many perimeter controls and posing the highest risk for silent tampering.

Student / opportunistic actor

Low sophistication but high physical or local access in lab environments. Often responsible for accidental misconfigurations or simple exploitation of weak segmentation.

3 Threat Scenarios

3.1 PLC manipulation

An attacker gains access to the engineering environment or PLC network and modifies control logic (e.g., ladder logic, function blocks, or setpoints). This may result in unsafe actuator behaviour, incorrect process thresholds, or bypassed interlocks.

External attackers typically achieve this via compromised engineering workstations or remote access abuse. Insiders can perform direct modifications with minimal detection risk.

3.2 Denial of Service (DoS)

An attacker disrupts communication between PLCs, SCADA, and HMI systems by flooding network segments, exploiting protocol weaknesses, or overwhelming control servers.

Industrial protocols such as Modbus/TCP or OPC may lack robust authentication or rate limiting, making them vulnerable to traffic-based disruption.

3.3 Unauthorized device access

A rogue device is introduced into the control network, either physically or via network misconfiguration. Once connected, it can scan, impersonate trusted nodes, or interact with PLC services.

This scenario is particularly realistic in lab environments where physical access is possible.

3.4 Malware infection via Engineering PC

The Engineering Workstation is compromised via phishing, malicious downloads, or removable media. Once infected, attackers can pivot into PLC networks, extract logic files, or deploy malicious firmware changes.

This is one of the most critical ICS attack vectors because the Engineering PC often has unrestricted access to control assets.

3.5 Data manipulation via MES / Webshop systems

Attacks targeting Manufacturing Execution Systems (MES) or web interfaces allow modification of production orders, process parameters, or scheduling data.

This can lead to incorrect production batches, financial losses, or downstream process disruption in physical systems.

4 Threat Table

Table 1: ICS Threat Analysis Matrix (IEC 62443-based)

Asset	Threat	Attacker	STRIDE Category	Impact	Example Scenario
Engineering PC	Malware infection	External / Student	Information Disclosure, Tampering	Critical	Phishing leads to PLC compromise
Engineering PC	Unauthorized access	Insider	Elevation of Privilege	Critical	Engineer account reused or misused
PLCs	Logic manipulation	External / Insider	Tampering, Elevation of Privilege	High	Modified ladder logic alters actuator behaviour
PLCs	Command injection	Student / External	Spoofing	High	Fake control commands sent via Modbus
SCADA/HMI	Session hijacking	External	Spoofing	High	Attacker impersonates operator session
Network Segments	Traffic flooding	External	Denial of Service	High	Broadcast storm disrupts PLC communication
PLC Network	Configuration exfiltration	External	Information Disclosure	High	PLC logic downloaded and analysed
MES System	Production manipulation	External / Insider	Tampering	High	Batch parameters altered remotely
SCADA/HMI	Denial of service	External	Denial of Service	Medium-High	Flooding causes operator loss of visibility
Webshop/API	Data modification	External	Tampering, Information Disclosure	Medium-High	Order data changed, affecting production
Network Switches	Rogue device connection	Student / Insider	Spoofing	Medium	Unauthorized laptop joins control VLAN